

Comprehensive Investigation of the September 2026 Revolut Cybersecurity Incident: Vulnerability Analysis, Structural Implications, and Defensive Frameworks for EU Financial Institutions

Executive Overview and Incident Chronology

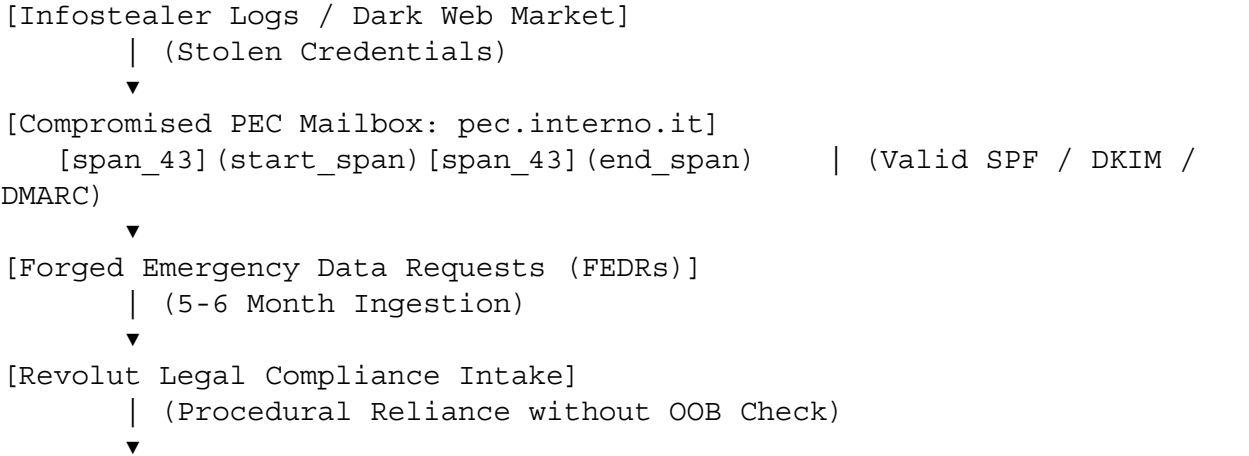
On September 11, 2026, global financial technology enterprise Revolut Bank confirmed a severe cybersecurity incident involving the unauthorized release of sensitive customer identity files, Know Your Customer (KYC) compliance records, and granular financial transaction histories. Unlike traditional cyber intrusions involving network perimeter breaches, malware deployments, or direct database compromises, the September 2026 incident was executed through an administrative social engineering attack classified as a Fraudulent Emergency Data Request (FEDR). Threat actors gained control of an active, certified government email address belonging to an Italian public authority and submitted forged law enforcement information demands to Revolut’s legal compliance channels over a period of five to six months. Because incoming communications originated directly from an authentic government domain—specifically the certified email domain of the Italian Ministry of the Interior (pec.interno.it)—and passed automated technical email authentication protocols (SPF, DKIM, DMARC), Revolut’s compliance personnel processed the demands under the operational assumption that they constituted lawful law enforcement mandates. This procedural breakdown resulted in the exfiltration of unredacted identity document scans, facial verification selfies, fiat account statements, and complete cryptocurrency transaction ledgers belonging to approximately 680 high-net-worth customers across approximately 30 countries, with account holders in France and Switzerland experiencing significant targeting. While Revolut’s core banking servers, transactional processing engines, and customer account balances remained uncompromised, the unauthorized release of non-revocable identity credentials triggered an active extortion campaign. Operating under aliases including "IAmNotAVillain" and "Revolut Smilik" on Telegram, the threat actors published stolen KYC dossiers of prominent figures and demanded ransoms ranging from \$3 million (in Monero) to 10,000 Bitcoin. Investigations by the Italian Postal Police (*Polizia Postale*) established that the email account was compromised via infostealer malware credential logs rather than a direct breach of core Italian police infrastructure.

Timeline Period	Operational Event & Tactical Description	Institutional Action & Impact
Initial Access Phase (April–May 2026)	Threat actors acquire compromised credentials for an official certified email mailbox (pec.interno.it) belonging to the Italian Ministry of the Interior via	Domain maintains valid cryptographic signatures (SPF, DKIM, DMARC), establishing trusted origin status.

Timeline Period	Operational Event & Tactical Description	Institutional Action & Impact
	dark web infostealer logs.	
Campaign Execution (May–Sept 2026)	Attackers systematically issue forged Emergency Data Requests targeting high-net-worth crypto holders over a 5 to 6 month period.	Requests pass automated perimeter mail filters; compliance staff fulfill inquiries without out-of-band verification.
Anomaly Detection & Containment (Sept 11, 2026)	Revolut detects anomalies during independent verification with the impersonated agency; blocks sender address and isolates the vector.	Access vector terminated. Revolut initiates notifications to European Central Bank (ECB), Lithuanian VDAI, UK ICO, and affected users.
Public Surface & Media Disclosure (Sept 12–14, 2026)	Excerpts of customer notices published by analyst ZachXBT; Revolut confirms impersonation attack while asserting core banking systems remain safe.	Media coverage highlights identity exposure; Revolut frames incident as external social engineering scam.
Extortion Escalation & Targeted Doxxing (Sept 15–17, 2026)	Threat actor "IAmNotAVillain" / "Revolut Smilik" demands ransom (\$3M to 10,000 BTC) on Telegram and publishes KYC files of high-profile victims.	KYC files, selfies, and passports of high-profile figures (Felix Römer, Alexander Shevchenko) are leaked on public channels.
Law Enforcement Audit (Sept 18–21, 2026)	Italian Postal Police (<i>Polizia Postale</i>) launch investigation into claims of a 147 GB police data breach linked to the attack.	Preliminary findings confirm no central breach of Interior Ministry systems (<i>Viminale</i>), isolating compromise to stolen PEC email credentials.

Technical & Vector Analysis: Initial Access, PEC Exploitation, and Infostealer Logs

The September 2026 Revolut breach illustrates a sophisticated exploitation of institutional trust frameworks rather than a technical failure of encryption or firewall architecture.



Certified Email (PEC) Infrastructure Compromise

The primary vector utilized by the attackers was an active mailbox on the Italian Certified Email network (*Posta Elettronica Certificata* or PEC), specifically under the pec.interno.it domain belonging to the Italian Ministry of the Interior. In Italy, PEC emails carry legal equivalence to registered physical mail, and public authorities use them for official administrative and legal communications.

Because the incoming messages originated from an authentic PEC address, all standard technical authentication checks cleared without triggering security warnings:

- **Sender Policy Framework (SPF):** Confirmed that sending server IP addresses aligned with authorized government mail gateways.
- **DomainKeys Identified Mail (DKIM):** Validated that the cryptographic signature attached to message headers matched the published public key of the government domain.
- **Domain-based Message Authentication (DMARC):** Enforced policy pass alignment, confirming message authenticity at the network transport layer.

Initial Access via Infostealer Logs

Threat intelligence analysis by Hudson Rock established that the threat actor did not execute a zero-day exploit or direct network intrusion against the Italian Ministry of the Interior. Instead, the attacker acquired compromised credentials for pec.interno.it accounts from dark web marketplaces selling infostealer malware logs (e.g., RedLine, Racoon, or Vidar). Over 300 compromised credentials associated with the pec.interno.it domain were identified in circulating infostealer datasets.

By harvesting valid session tokens and credentials, the actor logged directly into legitimate government mailboxes and submitted fraudulent Emergency Data Requests to Revolut Bank UAB over a period of five to six months without raising perimeter security alarms.

Extortion Escalation, Ransom Demands, and 147 GB Police Leak Claims

Following Revolut’s discovery and blocking of the compromised email vector on September 11, 2026, the threat actors pivoted from silent data harvesting to active extortion.

Extortion Parameter	Threat Actor Claim & Demonstrated Action	Verification & Official Finding
Threat Actor Aliases	Operating as "IAmNotAVillain" and "Revolut Smilik" on Telegram.	Confirmed active on public messaging channels publishing exfiltrated files.
Ransom Quantities Requested	Public posts demanded 10,000 BTC (~€673M) or \$3M in Monero (XMR).	Revolut confirmed receiving no direct contact or formal extortion demands from the group.
Targeted Doxxing & Leaks	Published complete KYC	Leaks verified by independent

Extortion Parameter	Threat Actor Claim & Demonstrated Action	Verification & Official Finding
	dossiers of prominent individuals to force compliance.	security researchers; included Gamdom CEO Felix Römer, tennis player Alexander Shevchenko, and footballer Georges Mikautadze.
147 GB Police Data Claim	Claimed possession of 147 GB (36,393 files across 5,223 folders) stolen from Italian police.	Italian Postal Police (<i>Polizia Postale</i>) investigation found no evidence of core network intrusion (<i>Viminale</i>); breach isolated to individual mailboxes.

The threat actor published unredacted KYC files—including high-resolution passport scans, onboarding selfies, residential addresses, and crypto transaction records—of high-profile figures to demonstrate data authenticity and maximize reputational pressure on the bank.

Analysis of Official Statements and Regulatory Communications

Public and regulatory responses have highlighted the intersection between operational security controls and statutory compliance rules.

Revolut Bank Official Position

Revolut maintained that its underlying core banking platform, transactional databases, and customer funds were never accessed or compromised. The institution characterized the event as an external impersonation scam where compliance staff were deceived by an authenticated public authority domain. Revolut confirmed that it isolated the vector, notified law enforcement and regulators, and directly contacted the ~680 affected account holders.

Regulatory Notifications

Formal incident disclosures were submitted across multiple European regulatory bodies:

- **State Data Protection Inspectorate (VDAI, Lithuania):** Lead supervisory authority under GDPR for Revolut Bank UAB.
- **European Central Bank (ECB):** Primary banking supervisor monitoring operational risk governance.
- **Information Commissioner's Office (ICO, UK):** Assessing data protection compliance for UK-resident victims.
- **Italian Postal Police (*Polizia Postale*):** Conducting criminal investigations into the fraudulent use of government certified mail infrastructure.

Structural Compliance Friction: FCA Guide FCG 3.2.11

The operational failure was exacerbated by existing statutory pressure on compliance teams. Under Section 3.2.11 of the UK Financial Conduct Authority (FCA) Financial Crime Guide

(FCG), regulated firms are required to ensure customer ID and transaction records can be retrieved "promptly and without delay" in response to Production Orders. The guide classifies restricting or delaying record sharing with authorities as poor practice and a potential breach of Money Laundering Regulations.

Threat actors weaponized this regulatory mandate. Knowing compliance personnel are trained to satisfy legal demands rapidly to avoid regulatory penalties, the attackers leveraged authenticated government emails to prompt swift fulfillment without triggering secondary verification checks.

Scope of Compromised Data Assets and Risk Vectors

Exfiltrated records represent a complete identity and financial dossier, creating severe physical and digital security risks for targeted account holders.

E [span_52] (start_span) [span_52] (end_span) XPOSED	
CUSTOMER DOSSIER	
Baseline Identity Profile	Financial & Asset Telemetry
- Full Legal Name & DOB	Account Statements & IBANs
Pos [span_18] (start_span) [span_18] (end_span) [span_39] (start_span) [span_39] (end_span) tal & Email Addresses	
- Passport & License Scans - Onboarding Verification Selfies	- Off-Chain Withdrawal Logs - Complete On-Chain BTC Ledger - Liquidity & Wealth Metrics

Risk Vectors for High-Net-Worth Account Holders

- Physical Targeting ("Wrench Attacks"):** Linking unredacted physical residential addresses directly with verified Bitcoin holding ledgers provides criminal syndicates with exact targeting profiles for extortion or home invasions.
- Bypassing Biometric & Identity Checks:** Unredacted passport scans accompanied by onboarding selfies allow threat actors to bypass automated video-KYC checks across third-party exchanges and fintech platforms.
- Hyper-Credible Social Engineering:** Access to granular transaction histories enables fraudsters to impersonate bank anti-fraud officers or tax authorities, citing exact past timestamps and transaction values to convince targets to execute emergency transfers.

Historical Baseline and Multi-Year Comparison (2022–2026)

To contextualize the September 2026 breach, it must be evaluated alongside Revolut’s historical security and regulatory profile.

Incident Event	Primary Vector & Mechanism	Impact & Scope	System Compromise Status
September 2022 Breach	Technical social engineering leading to internal system access.	Personal data of 50,150 customers exposed. Separately, Revolut lost ~\$20M corporate funds via a payment processing software flaw.	Direct System Intrusion.
July 2026 Dark Web Claim	Alleged dark web listing of 75M records for \$500.	Disputed by Revolut; determined to be aggregated legacy leak data or fabricated.	No Breach (Unsubstantiated claim).
June 2026 Supervisory Action	ECB administrative restriction on expanding specific product lines.	Product expansion paused due to governance concerns regarding operational risk controls at scale.	N/A (Regulatory governance mandate).
September 2026 FEDR Incident	Administrative impersonation via compromised Italian PEC email (pec.interno.it).	~680 high-net-worth accounts exfiltrated; active extortion campaign releasing KYC files.	Process Intrusion (Core servers untouched).

Strategic Defensive Recommendations for EU Financial Institutions

EU banking institutions must update administrative fulfillment workflows to counter government domain impersonation attacks.

1. Mandatory Out-of-Band Call-Back Verification (EU e-Evidence Framework)

- **Control Requirement:** Institutions must enforce mandatory out-of-band (OOB) telephone or portal verification—using independently sourced directory contact details—for all Emergency Data Requests prior to releasing sensitive customer files.
- **Regulatory Alignment:** Under the **EU e-Evidence Regulation (Regulation EU 2023/1543)**, emergency European Production Order Certificates carry an 8-hour binding compliance window. OOB verification protocols must be integrated into automated workflows to ensure identity validation completes within this statutory 8-hour limit.

2. Multi-Party Approval Governance (EBA Guidelines)

- **Control Requirement:** Implement a strict "four-eyes principle" (dual-person sign-off) before compliance staff can export non-revocable identity records, passport scans, or full account transaction ledgers.
- **Regulatory Alignment:** Directly satisfies **European Banking Authority (EBA)** ICT

Security and Governance Guidelines and **Digital Operational Resilience Act (DORA)** mandates requiring dual-authorization for sensitive data exports.

3. Technical Data Minimization (GDPR Article 5 & 25)

- **Control Requirement:** Configure compliance intake platforms to prevent single-click bulk exports of complete customer profiles. Systems must restrict legal fulfillment output strictly to the specific data points mandated in verified court orders.
- **Regulatory Alignment:** Enforces **GDPR Article 5(1)(c)** (*Data Minimization*) and **Article 25** (*Data Protection by Design and Default*).

Works cited

1. Revolut Leak: Hacker Claims Italian Police Breach and 147 GB of Data,
<https://www.it-connect.tech/revolut-leak-hacker-claims-italian-police-breach-and-147-gb-of-data/>
2. Revolut Data Breach: 5 Months, 680 High-Profile Accounts, \$3M,
<https://www.securityweek.com/revolut-data-breach-5-months-680-high-profile-accounts-3m-ransom/>
3. Revolut reportedly facing \$3m ransom demand after hackers steal,
<https://www.theguardian.com/business/2026/sep/17/revolut-reportedly-facing-3m-ransom-demand-after-hackers-steal-hundreds-of-customers-data>
4. Group Claiming Revolut Breach Demands 6,000 Monero, Says It,
<https://unchainedcrypto.com/group-claiming-revolut-breach-demands-6000-monero-says-it-hunted-big-crypto-holders/>
5. Revolut: hacker rivendica 147GB di dati, Polizia Postale indaga,
<https://www.mysolution.it/fisco/informazioni/news/2026/09/21/data-breach-di-revolut-nessuna-conferma-dellaccesso-ai-sistemi-di-polizia/>
6. Hackers demand Revolut hand over \$3m ransom amid data breach,
https://www.reddit.com/r/Revolut/comments/1wizhle/hackers_demand_revolut_hand_over_3m_ransom_amid/